

MODULE 15

Threats, Attacks & OSINT Basics

Phase 3 • Cybersecurity Foundations, Threat Awareness & Reconnaissance

1. Module Overview

The supplied module shifts students from a defensive-only mindset toward understanding how attackers operate. It presents reconnaissance as an early stage of attacks and OSINT as a way to build a profile of a person, organization, or system before deeper activity.

For a broader cybersecurity course, these skills apply across SOC analysis, penetration testing, threat intelligence, security engineering, security awareness, incident response, and attack-surface management.

2. Learning Objectives

- Describe the attacker's perspective and explain why reconnaissance is an early stage of many attacks.
- Define OSINT and explain legitimate offensive, defensive, intelligence, and investigative uses.
- Distinguish passive and active reconnaissance and explain their technical and legal risk difference.
- Understand WHOIS, DNS enumeration, search-engine operators, social-media reconnaissance, and metadata analysis.
- Explain how reconnaissance data can support phishing, spear phishing, social engineering, credential attacks, malware delivery, and BEC.
- Explain attack surface and how public exposure contributes to it.
- Build a basic reconnaissance profile from an authorized lab target.
- Evaluate evidence, uncertainty, and limitations instead of treating every discovery as a confirmed vulnerability.
- Describe ethical and legal boundaries for cybersecurity reconnaissance.

Core idea: Cybersecurity is not only about finding vulnerabilities. It is also about understanding exposure, attacker behavior, human factors, infrastructure, and how small pieces of information can combine into an attack path.

3. Thinking Like an Attacker

The source emphasizes that meaningful attacks begin before an exploit is executed. Attackers research targets to understand people, technologies, organizational structure, and possible entry points. This research phase is reconnaissance.

3.1 Why reconnaissance comes first

- Attackers need a target and objective.
- Useful information reduces uncertainty.
- Public information can reveal names, roles, technologies, domains, email patterns, documents, and business relationships.
- Reconnaissance can help select a believable social-engineering story or possible entry point.
- Some reconnaissance occurs outside the victim's infrastructure and may leave little or no direct evidence on the target.

3.2 Same information, different purpose

The same publicly available information can be interpreted differently depending on the goal. **Attackers use information to identify opportunities and plan attacks, while defenders use the same information to identify exposure and improve security.**

4. OSINT — Open Source Intelligence

OSINT is the practice of collecting and analyzing publicly available information to build a profile of a target. “Open source” here refers to publicly accessible information, not open-source software.

4.1 OSINT is a process, not just a tool

1. Define the target and authorization.
2. Define the intelligence question.
3. Collect relevant public information.
4. Verify important findings.
5. Correlate separate observations.
6. Analyze what the evidence means.
7. Document sources, timestamps, confidence, and limitations.

4.2 Common OSINT sources

- Websites and public web pages
- Search engines
- Public DNS information
- Domain-registration information
- Public social-media profiles/pages
- Public documents and metadata

5. Passive vs Active Reconnaissance

The source makes a strong distinction between passive and active reconnaissance. This is both a technical and ethical distinction.

Passive Reconnaissance	Active Reconnaissance
Uses information already available from public sources.	Directly interacts with target systems.
No direct traffic to the target is required.	Requests, packets, probes, or connections may reach target infrastructure.
Generally lower detection and operational risk.	May be logged, detected, blocked, or investigated.
Examples: public web research, public DNS/WHOIS information, search engines.	Examples include scanning and enumeration; detailed scanning is covered later in the course.
Still requires appropriate authorization in professional security work.	Requires explicit authorization and clearly defined scope.

5.1 Why active reconnaissance is more sensitive

- It creates traffic that a target may observe.
- It can trigger monitoring or defensive controls.
- It can unintentionally affect services.
- It can cross legal or contractual boundaries without authorization.

Rule: Never treat curiosity as authorization. In this course, use only the instructor-approved lab target and follow the stated scope.

6. WHOIS and Domain Intelligence

The source describes WHOIS as a public database protocol used for domain-registration information such as registrar, registration timing, and where privacy protection is not enabled contact details.

- Registrar
- Registration date/age
- Nameserver information
- Whether privacy protection is visible
- Other registration-related fields made available by the service

The source notes that newly registered domains are a common red flag in phishing infrastructure. Domain age is therefore a contextual signal when investigating suspicious links, not proof that a domain is malicious.

7. DNS Enumeration

DNS records can reveal infrastructure information. The source highlights MX records, subdomains, and naming conventions and mentions dig, nslookup, and DNSDumpster.

Record	Beginner explanation	Security relevance
A	Maps a hostname to an IPv4 address.	Public infrastructure information.
MX	Identifies mail-exchange servers.	May indicate email infrastructure/provider.
TXT	Text records used for multiple purposes.	May reveal verification or email-security information.
NS	Authoritative nameserver information.	Shows DNS infrastructure.
Subdomain	Named host under a domain.	May reveal separate services or functions.

Analyst habit: Record exactly what the DNS result says. Do not jump from “this hostname exists” to “this hostname is vulnerable.”

8. Search Engines & Google Dorking

The source calls advanced search-engine operators “Google dorking” or “Google hacking.” These operators help locate information that has already been indexed publicly and can also be used defensively to audit an organization's public footprint.

Operator	Purpose	Safe lab example
site:	Restrict results to a domain.	site:example.com
filetype:	Find a file type.	site:example.com filetype:pdf
intitle:	Search words in page titles.	site:example.com intitle:"index of"
inurl:	Search terms in URLs.	site:example.com inurl:admin
"exact phrase"	Search for an exact phrase.	"security policy"

- It can reveal documents an organization forgot were public.
- It can reveal indexed login portals or directory listings.
- It can reveal information useful for social engineering.
- Defenders can use the same technique to audit exposure.

Safety: Search results are not permission to access protected systems. If a result points toward a sensitive or unauthorized resource, stop and follow the lab scope.

9. Social Media & People-Focused Reconnaissance

Public employee profiles can reveal job titles, technologies, organizational structure, and timing information. Attackers may use such information to create believable phishing or social-engineering pretexts.

- Public job titles can reveal sensitive functions and organizational structure.
- Technology references can provide clues about an environment.
- Public project information can make phishing messages more convincing.
- Relationships can help an attacker impersonate a trusted person.
- Security teams can use these observations to improve awareness and reduce unnecessary exposure.

Privacy principle: Collect only information relevant to the cybersecurity question. Avoid unnecessary personal information.

10. Metadata Analysis

Public documents and images can contain metadata. The source mentions author information, usernames, GPS coordinates, software, and internal file paths, and identifies ExifTool as a metadata extraction tool.

Metadata	Possible security relevance
Author/username	May expose naming conventions or internal identities.
Software	May reveal software families or document-generation environment.
Internal file path	May disclose internal naming or directory conventions.
GPS coordinates	May expose location information from images.
Timestamp	May provide context, although timestamps can be stale or altered.

Metadata is evidence, not certainty. Validate and interpret it in context.

11. Common Cyber Attack Techniques

The source presents OSINT as an input into several common attack techniques. Students should understand each technique's mechanism, objective, OSINT connection, and defensive indicators.

11.1 Phishing and Spear Phishing

Phishing uses deceptive communication that impersonates a trusted source to persuade a target to click a link, open an attachment, disclose credentials, or perform another unsafe action. Spear phishing is targeted and may reference real names, projects, or events.

Indicator	Defensive question
Unexpected request	Was the request expected?
Urgency	Is the sender pressuring the recipient to bypass verification?
Identity	Does sender identity match the context?
Link	What destination does the link actually indicate?
Attachment	Was the file expected?

11.2 Credential Stuffing

Credential stuffing uses previously exposed username/password pairs against other services, relying on password reuse.

- Unique passwords reduce reuse risk.
- MFA can reduce the impact of stolen passwords.
- Users should not reuse passwords across important services.

11.3 Social Engineering / Pretexting

Social engineering manipulates people. Pretexting uses a fabricated identity or story, such as pretending to be IT support, to persuade someone to break normal security procedures.

11.4 Malware Delivery

The source describes malware delivery through email attachments, malicious links, or compromised websites. OSINT can help an attacker choose a delivery method that appears believable to a specific target.

12. The Attack Surface

The source defines attack surface as the sum of points where an unauthorized user could attempt to enter or extract data. It includes public websites, exposed services, employee accounts, third-party integrations, and publicly leaked information.

Category	Examples
Digital assets	Domains, websites, public portals, cloud services.
Infrastructure	Public DNS information, exposed services, remote-access systems.
Identity	Employee accounts, public roles, authentication entry points.
Human	Employees, vendors, executives, help-desk processes.

OSINT can help both attackers and defenders map the attack surface. An attacker may search for a weak point; a defender can search for the same exposure and reduce it.

13. From Reconnaissance to Attack

Stage	Example
Reconnaissance	Find domains, employees, technologies, public documents.
Preparation	Choose a believable target, story, or delivery method.
Initial access attempt	Phishing, credential abuse, malware delivery, or social engineering.
Follow-on activity	Attempt to achieve the objective after access.

Defense	Detection, investigation, containment, recovery, and lessons learned.
---------	---

This module does not teach unauthorized exploitation. Its purpose is to help students recognize how information exposure can contribute to later attack activity.

14. Hands-On Lab — OSINT Reconnaissance

The supplied module specifies a safe, pre-approved fictional company profile as the lab target. Students build a reconnaissance report using passive techniques.

Exercise 1 — Domain Intelligence

8. Perform a WHOIS lookup on the provided lab domain.
9. Record the registrar.
10. Record the registration date.
11. Record whether privacy protection is enabled.
12. Enumerate A, MX, and TXT records using an approved tool such as dig, nslookup, or an authorized DNS service.
13. Explain what the MX record indicates about email infrastructure.

Exercise 2 — Search-Operator Practice

14. Construct a site: query for the lab domain.
15. Construct a filetype: query for public documents.
16. Construct an intitle: or inurl: query relevant to the lab objective.
17. Record each query exactly.
18. Record whether it returned useful information.
19. Do not attempt to bypass access controls.

Exercise 3 — Reconnaissance Summary

20. Combine findings into an attack-surface overview.
21. Identify the most security-relevant public information.
22. Explain why it could have value to an attacker.
23. Explain what a defender could do to reduce unnecessary exposure.
24. Document limitations and uncertainty.

Lab boundary: Use only the instructor-provided fictional/safe target or another explicitly authorized target. Do not turn classroom reconnaissance into real-world testing.

15. Evidence & Documentation

Field	What to write
Finding ID	Unique identifier such as OSINT-01.
Source	URL, DNS result, WHOIS result, document, or other source.
Timestamp	When the evidence was observed.
Observation	What was directly seen.
Interpretation	What the observation may mean.
Security relevance	Why it matters.
Confidence	High/Medium/Low with a reason.
Limitation	What cannot be concluded from the evidence.

Example

Field	Example
Observation	A public PDF contains an author username.
Interpretation	The username may reveal an internal naming convention.
Security relevance	It could contribute to identity or social-engineering reconnaissance.
Limitation	The metadata does not prove the username is current or privileged.

16. Defensive Controls & Risk Reduction

The supplied module concentrates on reconnaissance and attack awareness. These are practical defensive connections to those concepts.

Exposure	Possible defensive focus
Unnecessary public documents	Review public files and remove unnecessary metadata.
Excessive employee information	Apply privacy and security-awareness guidance.
Password reuse	Use unique passwords and MFA.
Phishing exposure	Awareness, reporting procedures, email controls, and independent verification.
Unnecessary public services	Asset inventory and exposure review.
Forgotten domains/subdomains	Continuous asset inventory and ownership review.
Third-party exposure	Review vendor and integration security.

17. Cybersecurity Scenarios

Scenario 1 — Targeted phishing

An employee receives a message mentioning a real internal project and a manager's name.

- What OSINT clues might have been used?
- What makes this more targeted than generic phishing?
- What verification process should be used?

- What evidence should a defender preserve?

Scenario 2 — Suspicious domain

A suspicious email contains a recently registered domain resembling a legitimate organization.

- What domain information would you investigate?
- What does domain age tell you—and what does it not prove?
- What additional evidence would increase confidence that the message is malicious?

Scenario 3 — Public document

A public document contains an internal username and file-path information.

- What does the metadata reveal?
- What should be removed or reviewed?
- Why should the finding not automatically be called a vulnerability?

18. Knowledge Check

25. Define reconnaissance in cybersecurity.
26. Why can reconnaissance be difficult for defenders to detect?
27. Define OSINT in your own words.
28. Give three legitimate cybersecurity uses of OSINT.
29. Explain passive versus active reconnaissance.
30. Why is active reconnaissance more legally and operationally sensitive?
31. What information can WHOIS provide?
32. What does an MX record tell you?
33. What is Google dorking?
34. Name four search-engine operators from this module.
35. How can public social-media information support spear phishing?
36. Give three examples of document metadata that may matter to security.
37. Explain credential stuffing.
38. Explain pretexting.
39. How can OSINT support business email compromise?
40. What is an attack surface?
41. Why are people and information part of an organization's attack surface?
42. What evidence should be recorded during an OSINT investigation?
43. Why is authorization required before active testing?

19. Practical Assessment

Submit a reconnaissance report for the instructor-provided lab target.

Area	Expected evidence
Scope	Clear target and authorized activities.
WHOIS	Correctly recorded and interpreted registration information.
DNS	A/MX/TXT findings documented and explained.
Search operators	At least three documented queries and results.
Analysis	Explanation of attacker relevance and defensive meaning.
Evidence	Sources and timestamps recorded.
Safety	No unauthorized access, exploitation, credential testing, or unnecessary personal-data collection.

Communication	Another reader can understand what was found and what remains uncertain.
---------------	--

20. Cybersecurity Cheat Sheet

Concept	Remember
Reconnaissance	Research the target before deeper attack activity.
OSINT	Public information plus analysis produces intelligence.
Passive recon	Public research without direct target interaction.
Active recon	Direct interaction; requires explicit authorization.
WHOIS	Domain registration context.
DNS	Public infrastructure and naming information.
Google dorking	Advanced search operators for indexed information.
Metadata	Hidden file/image properties can reveal useful context.
Phishing	Deceptive communication to cause an action/disclosure.
Spear phishing	Targeted phishing using contextual information.
Credential stuffing	Reusing previously exposed credentials across services.
Social engineering	Manipulating people rather than only technology.
Pretexting	Fabricated story/identity used to justify a request.
Malware delivery	Methods used to deliver malicious payloads.
BEC	Business impersonation used to cause sensitive actions.
Attack surface	Relevant exposure points an attacker may target.
Evidence	Source + timestamp + observation + interpretation + limitations.

21. Source Basis & Further Reading

This document is based primarily on the user-supplied Module 15, “Threats, Attacks & OSINT Basics,” Phase 3, Week 6. The supplied module provides the core learning objectives, attacker-perspective framing, OSINT definition and uses, passive/active reconnaissance distinction, WHOIS, DNS, Google dorking, social-media reconnaissance, metadata analysis, common attack techniques, attack surface, ethical boundaries, lab exercises, assessment questions, and resource list.

The material has been reorganized into a broader cybersecurity teaching format so students can understand both attacker tradecraft and defensive implications rather than viewing the subject only through a SOC lens.

The supplied module lists OSINT Framework, theHarvester, Google Hacking Database (GHDB), and MITRE ATT&CK Reconnaissance Tactic as additional resources.